

CEHv13 — Module 13: Hacking Web Servers

Penetration Testing Lab Report

Date: October 4, 2026

Status: Lab completed — 7/7 tasks passed

1. Executive Summary

This report documents a controlled penetration testing exercise performed against lab targets within an isolated CEHv13 training environment (network range 10.10.1.0/24). The objective was to enumerate web server infrastructure, identify misconfigurations and vulnerable services, and demonstrate exploitation techniques against web servers hosted on Windows and Ubuntu lab machines. All activity was conducted strictly within the authorized lab scope for certification training purposes.

2. Scope and Objectives

Targets:

- www.moviescope.com — 10.10.1.19
- www.goodshopping.com — 10.10.1.19
- Windows 11 FTP server — 10.10.1.11
- Ubuntu Apache Tomcat server — 10.10.1.9

Attacking host: Parrot Security (root@parrot)

Objectives:

- Perform banner grabbing to fingerprint web server software.
- Use Nmap Scripting Engine (NSE) to enumerate services and detect WAF presence.
- Conduct a dictionary attack against an FTP service using THC-Hydra.
- Identify and exploit the Log4j (Log4Shell) vulnerability on an Apache Tomcat server.
- Mirror a target website for offline reconnaissance analysis.

3. Methodology

The engagement followed standard reconnaissance-to-exploitation methodology aligned with CEHv13 Module 13 (Hacking Web Servers): information gathering and banner grabbing, service enumeration via NSE scripts, WAF detection, credential attacks, vulnerability scanning, and exploitation of a known CVE. Tools used included Telnet, Nmap (with NSE scripts http-enum and http-trace), THC-Hydra, Searchsploit/Metasploit for Log4j identification, and wget (via sgpt shell) for website mirroring.

4. Findings

4.1 Banner Grabbing — www.moviescope.com

A Telnet session to port 80 of www.moviescope.com returned HTTP response headers revealing the web server software in use.

Finding: Server: Microsoft-IIS/10.0, X-Powered-By: ASP.NET, X-AspNet-Version: 4.0.30319.

```

DNS fwd/rev mismatch: www.moviescope.com != www.goodshopping.com
www.moviescope.com [10.10.1.19] 80 (http) open
GET / HTTP/1.0
Host: www.moviescope.com

HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Date: Sun, 04 Oct 2026 04:46:50 GMT
Connection: close
Content-Length: 4241

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">
<head>
    <meta charset="utf-8"/>
    <meta name="viewport" content="width=device-width, initial-scale=1, minimum-scale=1, maximum-scale=1"/>
    <meta name="description" content="Moviescope Web Site" />

```

Figure 1: Telnet banner grab against www.moviescope.com showing IIS/ASP.NET response headers.

4.2 NSE Enumeration — www.goodshopping.com

An Nmap scan (nmap -sV --script=http-enum www.goodshopping.com) was run against the host 10.10.1.19 to enumerate open services.

Finding: Port 3389/tcp (ms-wbt-server / RDP) was identified as open, alongside SMTP (25), HTTP/IIS (80), MSRPC (135), NetBIOS (139), Microsoft-DS (445), MS-SQL (1433), and MSMQ (1801). The http-enum script also flagged /login.aspx as a possible admin folder.

```

[root@parrot]-[/home/attacker]
#nmap -sV --script=http-enum www.goodshopping.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-04 00:59 EDT
Nmap scan report for www.goodshopping.com (10.10.1.19)
Host is up (0.0012s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
25/tcp    open  smtp           Microsoft ESMT
80/tcp    open  http           Microsoft IIS
|_ http-enum:
|_ /login.aspx: Possible admin folder
|_ http-server-header: Microsoft-IIS/10.0
135/tcp   open  msrpc          Microsoft Windows
139/tcp   open  netbios-ssn    Microsoft Windows
445/tcp   open  microsoft-ds?
1433/tcp  open  ms-sql-s       Microsoft SQL
1801/tcp  open  msmq?
2103/tcp  open  msrpc          Microsoft Windows
2105/tcp  open  msrpc          Microsoft Windows
2107/tcp  open  msrpc          Microsoft Windows

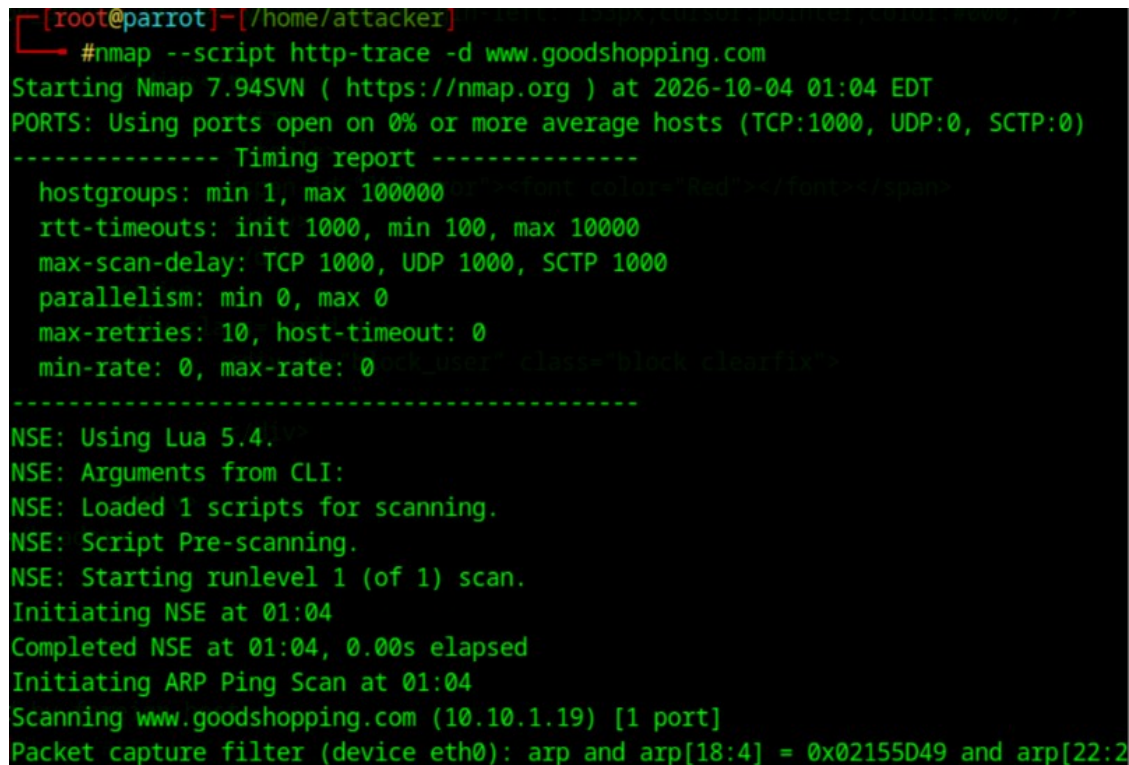
```

Figure 2: Nmap NSE (http-enum) scan output against www.goodshopping.com (10.10.1.19).

4.3 WAF Detection — www.goodshopping.com

An Nmap http-trace NSE script scan was used to assess whether a web application firewall was present on the target.

Finding: A web application firewall (WAF) was confirmed to be configured for www.goodshopping.com.



```
[root@parrot]~/home/attacker
#nmap --script http-trace -d www.goodshopping.com
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-10-04 01:04 EDT
PORTS: Using ports open on 0% or more average hosts (TCP:1000, UDP:0, SCTP:0)
----- Timing report -----
hostgroups: min 1, max 100000
rtt-timeouts: init 1000, min 100, max 10000
max-scan-delay: TCP 1000, UDP 1000, SCTP 1000
parallelism: min 0, max 0
max-retries: 10, host-timeout: 0
min-rate: 0, max-rate: 0
-----
NSE: Using Lua 5.4.
NSE: Arguments from CLI:
NSE: Loaded 1 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 1) scan.
Initiating NSE at 01:04
Completed NSE at 01:04, 0.00s elapsed
Initiating ARP Ping Scan at 01:04
Scanning www.goodshopping.com (10.10.1.19) [1 port]
Packet capture filter (device eth0): arp and arp[18:4] = 0x02155D49 and arp[22:2
```

Figure 3: Nmap http-trace NSE scan used to assess WAF presence on www.goodshopping.com.

4.4 FTP Credential Attack — Windows 11 Machine (10.10.1.11)

A dictionary attack was performed against the FTP service on 10.10.1.11:21 using THC-Hydra with a supplied wordlist (CEHv13 Module 13 Hacking Web Servers/Wordlists). The attack tested 41,174 login attempts across 16 parallel tasks.

Finding: Three valid credential pairs were recovered:

- Martin : apple
- Jason : qwerty
- Shiela : test

The credentials for user Martin were verified by establishing a live FTP session, confirming successful authentication (230 User logged in).

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-04 01:17:33
[DATA] max 16 tasks per 1 server, overall 16 tasks, 41174 login tries (l:238/p:173), ~2574 tries per task
[DATA] attacking ftp://10.10.1.11:21/
[21][ftp] host: 10.10.1.11 login: Martin password: apple
[STATUS] 4696.00 tries/min, 4696 tries in 00:01h, 36478 to do in 00:08h, 16 active
[STATUS] 4677.33 tries/min, 14032 tries in 00:03h, 27142 to do in 00:06h, 16 active
[21][ftp] host: 10.10.1.11 login: Jason password: qwerty
[21][ftp] host: 10.10.1.11 login: Shiela password: test
[STATUS] 4684.86 tries/min, 32794 tries in 00:07h, 8380 to do in 00:02h, 16 active
[STATUS] 4683.00 tries/min, 37464 tries in 00:08h, 3710 to do in 00:01h, 16 active
1 of 1 target successfully completed, 3 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-04 01:26:20

ftp 10.10.1.11 - Parrot Terminal

File Edit View Search Terminal Help
[attacker@parrot]~$ sudo su
[sudo] password for attacker:
[root@parrot]~# #ftp 10.10.1.11
Connected to 10.10.1.11.
220 Microsoft FTP Service
Name (10.10.1.11:root): Martin
331 Password required
Password:
230 User logged in.
```

Figure 4: THC-Hydra dictionary attack results against FTP on 10.10.1.11, with verified login as user Martin.

4.5 Log4j Vulnerability Identification — Apache Tomcat (Ubuntu, 10.10.1.9)

Apache Tomcat was installed on the Ubuntu lab machine and scanned from the Parrot Security machine. An exploit database search was used to cross-reference the discovered service against known vulnerabilities.

Finding: The target was identified as vulnerable to Apache Log4j 2 Remote Code Execution (Log4Shell), exploit reference java/remote/50592.py. The web server header returned during the Nmap scan against 10.10.1.9 confirmed the vulnerable Apache Tomcat instance.

```
Exploit Title | Path
-----|-----
Apache 2.2.2 - CGI Script Source Code Information Disclosure | multiple/remote/28365.txt
Apache ActiveMQ 5.2/5.3 - Source Code Information Disclosure | multiple/remote/33868.txt
Apache APISIX 2.12.1 - Remote Code Execution (RCE) | multiple/remote/50829.py
Apache CouchDB 3.2.1 - Remote Code Execution (RCE) | linux/remote/50914.py
Apache Flink 1.9.x - File Upload RCE (Unauthenticated) | java/webapps/48978.py
Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RC | multiple/webapps/50383.sh
Apache HTTP Server 2.4.50 - Path Traversal & Remote Code Execution (RC | multiple/webapps/50406.sh
Apache HTTP Server 2.4.50 - Remote Code Execution (RCE) (2) | multiple/webapps/50446.sh
Apache HTTP Server 2.4.50 - Remote Code Execution (RCE) (3) | multiple/webapps/50512.py
Apache James Server 2.3.2 - Remote Command Execution (RCE) (Authentic | linux/remote/50347.py
Apache Log4j 2 - Remote Code Execution (RCE) | java/remote/50592.py
Apache Shiro 1.2.4 - Cookie RememberME Deserial RCE (Metasploit) | multiple/remote/48410.rb
Apache Struts - 'ParametersInterceptor' Remote Code Execution (Metaspl | multiple/remote/24874.rb
Apache Tomcat 3.2.3/3.2.4 - 'Source.jsp' Information Disclosure | multiple/remote/21490.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC) | linux/dos/36906.txt
ApacheOfBiz 17.12.01 - Remote Command Execution (RCE) | java/webapps/50178.sh
NCSA 1.3/1.4.x/1.5 / Apache HTTPd 0.8.11/0.8.14 - ScriptAlias Source R | multiple/remote/20595.txt
Oracle Java JDK/JRE < 1.8.0.131 / Apache Xerces 2.11.0 - 'PDF/Docx' Se | php/dos/44057.md
```

Figure 5: Searchsploit results listing Apache-related exploits, including Log4j 2 RCE.

Exploit Title	Path
github.com/vanhauser/thc/the-hydra starting at 2026-10-04 01:26:30	
-----	-----
Apache 2.2.2 - CGI Script Source Code Information Disclosure	multiple/remote/28365.txt
Apache ActiveMQ 5.2/5.3 - Source Code Information Disclosure	multiple/remote/33868.txt
Apache APISIX 2.12.1 - Remote Code Execution (RCE)	multiple/remote/50829.py
Apache CouchDB 3.2.1 - Remote Code Execution (RCE)	linux/remote/50914.py
Apache Flink 1.9.x - File Upload RCE (Unauthenticated)	java/webapps/48978.py
Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RC	multiple/webapps/50383.sh
Apache HTTP Server 2.4.50 - Path Traversal & Remote Code Execution (RC	multiple/webapps/50406.sh
Apache HTTP Server 2.4.50 - Remote Code Execution (RCE) (2)	multiple/webapps/50446.sh
Apache HTTP Server 2.4.50 - Remote Code Execution (RCE) (3)	multiple/webapps/50512.py
Apache James Server 2.3.2 - Remote Command Execution (RCE) (Authentic	linux/remote/50347.py
Apache Log4j 2 - Remote Code Execution (RCE)	java/remote/50592.py
Apache Shiro 1.2.4 - Cookie RememberME Deserial RCE (Metasploit)	multiple/remote/48410.rb
Apache Struts - 'ParametersInterceptor' Remote Code Execution (Metaspl	multiple/remote/24874.rb
Apache Tomcat 3.2.3/3.2.4 - 'Source.jsp' Information Disclosure	multiple/remote/21490.txt
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)	linux/dos/36906.txt
ApacheOfBiz 17.12.01 - Remote Command Execution (RCE)	java/webapps/50178.sh
NCSA 1.3/1.4.x/1.5 / Apache HTTPd 0.8.11/0.8.14 - ScriptAlias Source R	multiple/remote/20595.txt
Oracle Java JDK/JRE < 1.8.0.131 / Apache Xerces 2.11.0 - 'PDF/Docx' Se	php/dos/44057.md

Figure 6: Apache Log4j 2 RCE exploit entry (java/remote/50592.py) selected as the applicable exploit.

4.6 Website Mirroring — certifiedhacker.com

The target website was mirrored locally using wget (via sgpt shell) with recursive mirroring, link conversion, and extension adjustment options, for offline reconnaissance and content review.

Finding: Site successfully mirrored (index.html, robots.txt, and associated page-requisites retrieved); server identified as resolving to IP 162.241.216.11 over HTTPS.

```

--[root@parrot]~[/home/attacker] --hydra -l root -L root -u http -U http -P 2026-10-04 01:26:30
-- #sgpt --shell "Mirror the target website certifiedhacker.com"
wget --mirror --convert-links --adjust-extension --page-requisites --no-parent https://certifiedhacker.
n (100% 8500 (8.3K) [text/html] saved, 3 valid passwords found
[2026-10-04 02:01:52] https://certifiedhacker.com/
resolving certifiedhacker.com (certifiedhacker.com)... 162.241.216.11
connecting to certifiedhacker.com (certifiedhacker.com)[162.241.216.11]:443... connected.
HTTP request sent, awaiting response... 200 OK
length: 8500 (8.3K) [text/html]
saving to: 'certifiedhacker.com/index.html'
certifiedhacker.com 100%[=====] 8.30K --.-KB/s in 0s
connected to 162.241.216.11
2026-10-04 02:01:54 (35.2 MB/s) - 'certifiedhacker.com/index.html' saved [8500/8500]
loading robots.txt; please ignore errors.
-2026-10-04 02:01:54-- https://certifiedhacker.com/robots.txt
reusing existing connection to certifiedhacker.com:443.
HTTP request sent, awaiting response... 200 OK
length: 8500 (8.3K) [text/html]
saving to: 'certifiedhacker.com/robots.txt.html'
certifiedhacker.com 100%[=====] 8.30K --.-KB/s in 0s

```

Figure 7: Website mirroring of certifiedhacker.com via wget (invoked through sgpt shell).

5. Risk Assessment

Finding	Risk Level	Potential Impact
Weak FTP credentials (dictionary-crackable)	High	Unauthorized file system access, credential reuse risk

Unpatched Log4j on Apache Tomcat	Critical	Remote code execution, full host compromise
Exposed RDP service (3389)	Medium	Potential brute-force / lateral movement vector
Possible admin login page exposed (/login.aspx)	Medium	Increases attack surface for credential attacks
Verbose HTTP banners (IIS/ASP.NET versions)	Low	Aids attacker fingerprinting and exploit targeting

6. Recommendations

- Patch the Apache Tomcat / Log4j installation immediately to a version unaffected by CVE-2021-44228 (Log4Shell) or apply the recommended mitigations.
- Enforce strong, complex password policies and account lockout thresholds on the FTP service to prevent dictionary/brute-force attacks.
- Restrict or VPN-gate RDP (3389) access rather than exposing it directly to the network.
- Suppress verbose server banners (Server, X-Powered-By, X-AspNet-Version headers) to reduce fingerprinting risk.
- Review and restrict access to administrative interfaces such as /login.aspx, applying IP allow-listing where feasible.
- Continue WAF deployment on customer-facing applications (confirmed present on www.goodshopping.com) and ensure rule sets are kept current.

7. Conclusion

The lab exercise successfully demonstrated the full web server attack chain covered in CEHv13 Module 13 — from passive banner grabbing and NSE-based enumeration through credential attacks and exploitation of a critical RCE vulnerability (Log4Shell). All seven assessment tasks were completed successfully (7/7, duration 2 hours 2 minutes). The findings reinforce the importance of patch management, credential hygiene, and attack surface reduction for internet-facing web infrastructure.

Appendix A: Lab Score Report

The following score report confirms successful completion of all seven graded tasks in CEHv13 Module 13: Hacking Web Servers.

Module 13: Hacking Web Servers

CEHV13

Duration: 2 hours, 2 minutes



Congratulations, you passed!

- ☒ Perform banner grabbing using Telnet on the website www.moviescope.com. Identify the web-server application used to host the website. Score: 1

Microsoft-IIS/10.0
- ☒ Use Nmap Scripting Engine (NSE) to extract information about the website www.goodshopping.com. Enter the port number of the ms-wbt-server service, which is open on the web server. Score: 1

3389
- ☒ Use Nmap Scripting Engine (NSE) to check whether a web-application firewall is configured for the website www.goodshopping.com. Enter YES if a web-application firewall is configured for www.goodshopping.com or NO otherwise. Score: 1

yes
- ☒ Perform a dictionary attack using the THC Hydra tool to remotely access the FTP server hosted on the Windows 11 machine. Note: The wordlist file is located at CEHV13 Module 13 Hacking Web Servers/Wordlists. Enter the password of the user Martin. Score: 1

apple
- ☒ Perform a dictionary attack using the THC Hydra tool to remotely access the FTP server hosted on the Windows 11 machine. Enter the name of the user with the password "qwerty." Score: 1

Jason
- ☒ Install Apache Tomcat web server on Ubuntu machine and use Parrot Security machine to scan for web server and exploit log4j vulnerability present in the Apache Tomcat on Ubuntu machine to gain access to the vulnerable server. Determine the http-server-header that was found during nmap scan on 10.10.1.9. Score: 1

Figure 8: Detailed score report — Module 13: Hacking Web Servers, 7/7 passed.